

Arjun Giriraj Day 21

PART A – FUNDAMENTALS

1. What does OWASP stand for?
Open Worldwide Application Security Project.
2. What is the purpose of the OWASP Top 10?
To highlight the major security risk commonly found in web application.
3. Why is the OWASP Top 10 useful for cybersecurity students?
It gives students a basic understanding of common web security problems. It is also useful for learning how vulnerabilities can affect an application and how they can be prevented.
4. What is a vulnerability?
A vulnerability is a weakness in the system which can be misused to gain unauthorized access.
5. What is security risk?
Security risk is the possibility that a vulnerability or threat can cause harm to a system.
6. What is an asset?
An asset is something valuable that need strong protection.
7. What is a threat?
A threat is something that can harm the assets.
8. What is impact?
Impact means the damage caused when then security problem happens.
9. Explain Authentication.
It is the process of checking who the user is.
10. Explain Authorization.
Authorization decides what authenticated user is allowed to do.
11. What is the difference between Authentication and Authorization?
Authentication checks who the user is while Authorization decides what authenticated user is allowed to do.

PART B – OWASP TOP 10:2025

Write one or two sentences explaining each category:

12. A01:2025 – Broken Access Control
It defines the risk where a normal user can access something like admin panel which they are not allowed to do.
13. A02:2025 – Security Misconfiguration
It occurs when security systems are configured insecurely.

14. A03:2025 – Software Supply Chain Failures
This involves security problems in the software components, dependencies, tools or processes used to build an application.
15. A04:2025 – Cryptographic Failures
It happens when sensitive information is properly protected using appropriate cryptographic and encryption method.
16. A05:2025 – Injection
Injection happens when malicious input is sent as part of a command or query.
17. A06:2025 – Insecure Design
It is caused by missing or ineffective security designs.
18. A07:2025 – Authentication Failures
It happens when an application could not protect authenticated user workflow.
19. A08:2025 – Software or Data Integrity Failures
It is caused when a system accepts the software update without verifying the source.
20. A09:2025 – Security Logging and Alerting Failures
It happens when security activity is not properly logged or alerted on.
21. A10:2025 – Mishandling of Exceptional Conditions
When an unexpected system error causes an application to skip an important security check.

PART C – SAFE PRACTICAL ANALYSIS

Analyze these FICTIONAL scenarios.

SCENARIO 1:

A normal student can access an admin-only page.

Identify:

Asset: Sensitive administrative data.

Security Problem: The application is not checking whether the student has permission to access admin page.

OWASP Category: A01:2025 Broken Access Control.

Possible Impact: The student might read or modify the sensitive information.

High-Level Defensive Recommendation: The application should enforce authorization checks on the server and make sure users can only perform actions which is allowed to them.

SCENARIO 2:

A production application displays internal file paths and detailed debug errors.

Identify:

OWASP Category: A02:2025 Security Misconfiguration.

Why: Detailed debug information should normally be exposed to developers not on application to show every users. Internal file paths can reveal information about the application's infrastructure and configuration.

SCENARIO 3:

A company unknowingly installs a compromised third-party software dependency.

Identify:

OWASP Category: A03:2025 Software Supply Chain Failures

Why: The application depends on compromised third-party software dependency which introduces a security risk into the company's software supply chain.

SCENARIO 4:

A sensitive approval workflow was designed without an approval control.

Identify:

OWASP Category: A06:2025 Insecure Design

Why: The security control was missing at the design level. The workflow should have included an approved mechanism.

SCENARIO 5:

An application does not record important suspicious authentication activity.

Identify:

OWASP Category: A09:2025 – Security Logging and Alerting Failures

Why: Important authentication activity are not being properly logged or monitored. This can make it difficult to detect suspicious activity and investigate security incidents.

PART D – STUDENT PORTAL ASSETS

Imagine a fictional internship portal.

List five important assets.

Asset 1: Student Personal Information

Why it needs protection: It contain names, contact information, student details, and other personal data.

Asset 2: Student Login Credentials

Why it needs protection: Usernames and passwords protect the student's account. If they are compromised, someone unauthorized can access student's account.

Asset 3: Academic Records

Why it needs protection: Marks, grades, attendance and other academic records are sensitive information and should only be accessible to authorized users.

Asset 4: Internship and Application Data

Why it needs protection: This can contain resumes, applications, internship details and other information. Unauthorized access could expose private student information.

Asset 5: Student Portal Database

Why it needs protection: The database may contain many types of sensitive student information. Protecting it helps prevent unauthorized access, modification, or loss of data.